DOCUMENTACION TECNICA · TOTAL CLEAN CAR

Informe de auditoria — LavadoCarros

Proyecto: Total Clean Car

Version: 1.1

Fecha: 11/10/2026

Elaborado por: Auditoria tecnica

Fecha: 2026-09-15 (revisado 2026-10-10) · **Version:** 1.1
Ruta: `/home/server-dt/Documentos/lavado_de_carros`

Resumen ejecutivo

Sistema de reservas de lavado de vehiculos a domicilio. **Es el proyecto mejor construido de los auditados hasta ahora.** La arquitectura esta bien separada en capas, la autenticacion y la autorizacion estan resueltas con cuidado, hay rate limiting razonado, la subida de archivos esta acotada y **el codigo explica sus propias decisiones** en comentarios que resultaron exactos al contrastarlos.

Tiene datos de un piloto funcional completo: 18 reservas que recorrieron todo el ciclo, con asignacion de lavador, evidencia, pago y calificacion.

Los problemas no estan en el codigo sino alrededor:

1. **PostgreSQL esta expuesto a la red local** (puerto 5437), sin que firewalld lo cubra.
2. **No hay ningun respaldo**, y aqui se perderian tanto la base como las evidencias fotograficas y los comprobantes de pago.
3. **El webhook de pagos no valida firma.** Hoy es inocuo porque la pasarela no esta conectada; sera grave el dia que se conecte.

Estado general

🟡 **OPERATIVO CON OBSERVACIONES**

Arquitectura

Tres contenedores (React+nginx / Express+Prisma / PostgreSQL 15.18), sin cache ni colas, con integraciones de SMTP y Twilio. Separacion rutas → controladores → servicios → Prisma. Adecuada.

Codigo

Buena calidad. Destacan tres decisiones correctas y poco frecuentes:

- La autenticacion **revalida contra la base en cada peticion**, de modo que suspender una cuenta corta el acceso al instante en vez de esperar 24 h.
- El rate limiting usa **id de usuario** como clave, no IP, con el razonamiento documentado sobre el falseo de `X-Forwarded-For`.
- La verificacion de pertenencia esta presente: un cliente no puede pagar la reserva de otro.

Docker

Correcto en lo esencial: `depends_on` con `service_healthy`, volumenes declarados, politica de reinicio. Falta healthcheck en backend y frontend, y los tres puertos se publican en todas las interfaces.

Base de datos

PostgreSQL 15.18, 15 entidades, integridad referencial coherente (`RESTRICT` en lo identificatorio, `SET NULL` en lo circunstancial). Sin procedimientos ni triggers. `Usuario.rol` es texto libre en vez de enum.

Seguridad

3 hallazgos altos, 4 medios, 2 bajos, 1 informativo. **Ningun critico.** Lo fundamental —contrasenas con bcrypt, secreto JWT fuerte, autorizacion por rol, validacion de subidas, sin superficie de SQL Injection— esta bien resuelto.

Documentacion

Existia documentacion previa abundante (8 archivos). Se conserva completa y queda clasificada: 3 vigentes, 2 desactualizados, 1 incompleto, 1 duplicado, 1 no verificable. **La API ya publicaba Swagger**, que es la mejor documentacion tecnica que tenia el proyecto.

Backup

🔴 **Inexistente**, y con tres elementos irrecuperables: base, archivos subidos y `.env`.

Operacion

Sin monitoreo ni healthcheck de aplicacion. Logs sin persistencia.

Mobile

- **N/A.**

Riesgos

Riesgo	Probabilidad	Impacto	Exposicion
Perdida total de datos del piloto	media	alto	**alta** — sin respaldo
Acceso directo a PostgreSQL desde la LAN	media	alto	**alta**
Fraude via webhook al conectar la pasarela	**alta si se conecta sin corregir**	alto	**alta**
Perdida de evidencias y comprobantes	media	alto	alta — son respaldo documental del servicio y del cobro
Crecimiento sin limite de `uploads_data`	media	medio	media
Perdida del codigo	baja	medio	media — sin remoto git

Inconsistencias

INC-01 — Documentacion previa anterior al codigo

`DOCUMENTACION_TECNICA.md`, `ANALISIS.md` y `MODELO_BASE_DATOS.md` son del 2026-08-28; el codigo siguio cambiando hasta el 2026-08-31 (rate limiting y flujo de comprobantes). **Revisar:** los tres documentos. **Impacto:** medio, quien los lea creera que no hay rate limiting.

INC-02 — Version del producto sin unificar

`backend` declara `1.0.0`, `frontend` declara `0.1.0`, y no hay etiquetas en git. **Impacto:** bajo, pero impide referirse a "la version X" en soporte.

INC-03 — `idea.md` duplica `IDEA_NEGOCIO.md`

Dos documentos de negocio solapados. **Impacto:** bajo.

INC-04 — Los roles validos viven en un comentario

El schema declara `rol String` y los cuatro valores validos estan solo en un comentario. Codigo y base no coinciden en el nivel de garantia.
Impacto: medio.

Documentacion faltante (antes de esta auditoria)

Faltaban: manual de usuario, manual de administrador, manual de soporte, documentacion de operacion, de continuidad, plan de pruebas y gestion de versiones. Todo queda creado en `docs/`.

Recomendaciones

ID	Hallazgo	Categoria	Severidad	Recomendacion
CONT-01	Sin respaldo de base, archivos ni secretos	Continuidad	🔴 CRITICO	Respaldo diario de los tres. Script en `docs/12_CONTINUIDAD`
SEC-01	PostgreSQL alcanzable desde la LAN	Seguridad	🟠 ALTO	Publicar como `127.0.0.1:5437:5432`
SEC-02	Webhook de pagos sin validacion de firma	Seguridad	🟠 ALTO	**Resolver ANTES de conectar la pasarela.** Validar HMAC del proveedor
SEC-03	API y Swagger expuestos sin autenticacion	Seguridad	🟠 ALTO	API en `127.0.0.1` tras nginx; Swagger fuera de produccion
SEC-04	CORS refleja cualquier origen con credenciales	Seguridad	🟡 MEDIO	Lista blanca de origenes
SEC-05	Sin cabeceras de seguridad	Seguridad	🟡 MEDIO	Agregar `helmet`
SEC-07	`rol` como texto libre sin restriccion	Seguridad	🟡 MEDIO	Convertir a `enum` de Prisma
OPS-01	Backend y frontend sin healthcheck	Operacion	🟡 MEDIO	Usar `GET /api/health`, que ya existe
OPS-02	`uploads_data` crece sin politica de purga	Operacion	🟡 MEDIO	Definir retencion
SEC-06	`X-Powered-By` expone el framework	Seguridad	🔵 BAJO	Cubierto por helmet
SEC-08	Limite de cuerpo JSON de 20 MB	Seguridad	🔵 BAJO	Bajar a 1-2 MB
INC-01	Documentacion previa desactualizada	Documentacion	🟡 MEDIO	Actualizar o marcar como historica
GES-01	Repositorio sin remoto	Gestion	🟡 MEDIO	Publicar en el git de la empresa
PEND-01	Matriz de permisos por rol sin verificar	Pruebas	🟡 MEDIO	Completar la matriz de `docs/13_PRUEBAS`
NEG-01	Vigencia del piloto sin definir	Negocio	🟡 MEDIO	Definir si pasa a produccion

Prioridad recomendada

1. **CONT-01** — respaldo. Hay datos de negocio reales que hoy se perderian.
2. **SEC-01** — cerrar PostgreSQL. Es un cambio de una linea.
3. **SEC-02** — webhook. **Bloqueante para conectar pagos**, no urgente mientras no se conecte.
4. **SEC-03** — exposicion de la API.
5. OPS-01, SEC-04, SEC-05, SEC-07.

6. El resto.

Ningun cambio fue aplicado durante esta auditoria.

Anexo — Inconsistencia de propiedad de archivos (detectada al cerrar)

Al intentar registrar la documentacion en git aparecio un problema de permisos. Diagnostico:

Dentro del proyecto conviven archivos de dos duenos distintos. Son de `root`, entre otros:

```
.env
.git/COMMIT_EDITMSG
.git/objects/  (varios subdirectorios)
backend/prisma/seed-demo.js
backend/prisma/demo-imagenes.js
backend/src/utils/credenciales.js
backend/src/utils/firmaArchivos.js
```

El resto pertenece a `server-dt`, que es el dueno del directorio y el usuario con el que se opera normalmente.

Causa: en algun momento se trabajo en el proyecto como `root` (docker, edicion directa o git), y esos archivos quedaron con ese dueno.

Impacto:

- `server-dt` **no puede hacer commit** en el repositorio: git falla con "*permisos insuficientes para agregar un objeto*".
- `.env`, que contiene los secretos, pertenece a root. El usuario habitual no puede leerlo ni rotarlo sin elevar privilegios.
- Un despliegue o actualizacion ejecutado como `server-dt` fallaria de forma poco evidente.

Recomendacion (no aplicada): unificar la propiedad del proyecto.

```
sudo chown -R server-dt:server-dt /home/server-dt/Documentos/lavado_de_carros
sudo chmod 600 /home/server-dt/Documentos/lavado_de_carros/.env
```

Y en adelante, no operar el proyecto como root. Esta correccion **no se aplico en esta auditoria** porque cambia permisos del sistema de archivos y excede el alcance de "analizar y documentar".

Severidad: 🟡 MEDIO (`OPS-03`).

Revisión 2026-10-10

Version del informe: 1.1 · **Codigo revisado:** `a27181b` (2026-10-08) · Solo lectura: no se inicio sesion en la app ni se escribio en la base.

> Este repositorio es **publico**. Esta seccion describe cada falla y su correccion, pero omite a proposito los pasos para reproducirla. El detalle tecnico completo esta en la copia interna de la auditoria (`Documentos/AUDITORIA-2026-10-10/`, fuera del repo).

Estado general: 🔴 CRITICO

El codigo mejoro mucho desde el 15-sep (helmet, refresh revocable, 203 pruebas, CI, respaldo diario verificado). El estado empeora por la operacion: el panel ya se usa desde Internet por HTTP y siguen vigentes credenciales que estan publicadas.
El sistema sigue en piloto: 22 reservas en total, solo 4 desde el 15-sep y ninguna futura.

Pendientes del 2026-09-15

ID	Tema	Estado al 2026-10-10
CONT-01	Respaldo	🟡 PARCIAL: cron diario con dump verificado y restauracion probada, pero queda en el mismo servidor, falto el del 09-oct (corte del servidor) sin alerta y la retencion mensual no funciona (LAV-N05)
SEC-01	PostgreSQL publicado en todas las interfaces	🔴 ABIERTO y agravado: el usuario de la app es superusuario y su contrasena coincide con la versionada
SEC-02	Webhook de pagos sin firma	🔴 ABIERTO y ya aprovechable (LAV-N01)
SEC-03	Swagger publico	🟠 ABIERTO, ahora tambien desde Internet
SEC-04	CORS refleja cualquier origen	🟡 ABIERTO (impacto bajo: la sesion va por Bearer)
SEC-05/06	helmet, X-Powered-By	🟢 CERRADO en el backend; el HTML del frontend sigue sin CSP
SEC-07	`rol` como texto libre	🟡 ABIERTO
SEC-08	Cuerpo JSON de 20 MB	🔵 ABIERTO en el puerto directo del backend
SEC-10	Sin HTTPS	⚪ El APK en claro es una **decision aceptada**. Por el mismo canal viajan el login del panel y el refresh de 7 dias
OPS-01	Healthchecks	🟡 ABIERTO: en el arranque del 09-oct nginx murio antes que el backend y solo volvio por el reinicio automatico
OPS-03	Archivos de root	🟢 CERRADO
GES-01	Sin remoto git	🟢 Resuelto, pero el remoto es **publico**
—	Cuentas del seed	🔴 Las 4 cuentas del seed (admin incluida) siguen con la contrasena del seed
—	Precios de moto / adicionales	🟠 Siguen sin cargar
—	Boton "no asistio"	🟡 La API existe; ningun boton la llama
—	Correo y Twilio	🟡 Sin configurar: no sale ninguna notificacion

Hallazgos nuevos

ID	Sev.	Hallazgo	Correccion
LAV-N01	🔴	Un cliente puede dejar como **pagada** su propia reserva, por el flujo de pago con tarjeta y el webhook sin firma	Deshabilitar webhook y pago con tarjeta mientras no haya pasarela; al conectarla, firma HMAC del proveedor, no exponer la referencia interna y conciliar el monto
LAV-N02	🔴	Credenciales reales (seed y base de datos) en el repositorio publico, y defaults de BD y JWT en `config/index.js`	Rotar las 4 cuentas del seed y la clave de PostgreSQL; publicar 5437 solo en `127.0.0.1`; repo privado; quitar valores reales de los ejemplos y defaults del codigo
LAV-N03	🟠	nginx corta toda subida de mas de 1 MB (falta `client_max_body_size`): fotos de celular y comprobantes fallan	`client_max_body_size 32m` en `/api/` y redimensionar en el cliente
LAV-N04	🟠	"Cobrado" del mes pierde lo cobrado el ultimo dia (rango en UTC contra instantes)	Rango `[desde 00:00 EC, hasta+1 00:00 EC)` y prueba con un pago a media tarde del ultimo dia
LAV-N05	🟠	La retencion mensual de respaldos nunca se activa (`respaldo.sh:321`)	Leer bien el dia y conservar el primer paquete de cada mes
LAV-N06	🟡	El Excel/PDF de un mes trae la hoja Resumen del mes en curso	Usar el resumen del periodo
LAV-N07	🟡	KPIs del Dashboard sin techo de fecha y con criterios de estado distintos entre pantallas; 18 reservas pasadas siguen abiertas	Rango cerrado y un solo criterio de "lavado hecho"
LAV-N08	🟡	Admin y operador no pueden cambiar su contrasena desde la app	"Cambiar mi contrasena" para todos los roles
LAV-N09	🟡	El router reescribe la IP de origen: los limites por IP son globales	Reenvio sin SNAT o proxy de borde; captcha en el registro
LAV-N10	🟡	Un lavador puede crear reservas para cualquier cliente y listar vehiculos de todos	Restringir roles en esas rutas
LAV-N11	🔵	El cupo mensual del plan cuenta reservas de meses futuros	Rango del mes cerrado
LAV-N12	🔵	Reservas simultaneas de franjas distintas chocan al generar el codigo	Secuencia de BD y reintento
LAV-N13	🔵	Refresh en `localStorage` y HTML sin CSP	CSP en nginx; a futuro cookie httpOnly
LAV-N14	🔵	Logs del backend sin persistencia ni IP	Rotacion o volumen; registrar usuario e IP real
LAV-N15	🔵	Dependencias vulnerables (express/qs, nodemailer, axios, y ~100 de build por CRA)	`npm audit fix` sin `--force`, subir axios, migrar a Vite

Mejoras sugeridas (priorizadas)

#	Sugerencia	Esfuerzo	Valor
1	Rotar credenciales, cerrar 5437, repo privado, apagar webhook y tarjeta (LAV-N01/N02)	S	Muy alto
2	Subidas de mas de 1 MB y compresion en el cliente (LAV-N03)	S	Muy alto
3	Retencion mensual, copia externa cifrada y alerta si falta un respaldo	S-M	Alto
4	Swagger solo fuera de produccion, 3042 en `127.0.0.1`, `CORS_ORIGINS`	S	Alto
5	Cuadre de caja: rangos en "cobrado", resumen del periodo, un criterio de estados (LAV-N04/N06/N07)	S	Alto
6	Boton "No asistio" y cierre nocturno de reservas vencidas	S	Alto
7	Precios de moto y catalogo de adicionales	S	Alto
8	SMTP y recordatorios por el gateway WhatsApp propio en lugar de Twilio	M	Alto
9	"Cambiar mi contrasena" y politica minima (LAV-N08)	S-M	Medio-alto
10	Fidelizacion: sellos, referidos, recordatorio a los 30 dias, calificacion por WhatsApp	M	Alto
11	Pago por QR/transferencia antes que tarjeta; luego pasarela local con webhook firmado	M-L	Alto
12	Healthchecks con `depends_on: service_healthy` y logs con rotacion	S	Medio
13	Roles por ruta, `rol` como enum, tope de rango en exportaciones	S-M	Medio
14	Migrar de CRA a Vite	M	Medio

No verificado

Alcance desde Internet de 5437 y 3042 (requiere escaneo externo); LAV-N01 no se ejecuto (sale de leer el codigo); no se corrio la suite Jest ni se probo una restauracion; no se revisaron las cuentas demo ni el contenido de `HISTORIAL_CHAT.md` del repo publico.